Sage Bionetworks

National Science Foundation Program Directors, Pathways to Enable Secure Open-Source Ecosystems (PESOSE), NSF 26-506

Subject: Letter of Collaboration, "RedTwin: AI-Enabled Digital Twins for Continuous Red Teaming of Open-Source Ecosystems" (Track 3)

Dear Program Directors,

My name is Luca Foschini. I am President and Chief Executive Officer of Sage Bionetworks, a nonprofit biomedical research organization whose mission is to make health research data, and the tools that operate on it, openly available and responsibly governed. Sage builds and maintains open-source infrastructure for sharing scientific data, curates and hosts data resources contributed by investigators and research consortia, and develops the governance and consent frameworks that make sharing sensitive human-subjects data possible in the first place. Our platform is Synapse (synapse.org), an open-source repository and collaboration environment for biomedical research data. Synapse attaches consent terms and data-use conditions to the data itself, reviews access investigator by investigator, and records what was accessed and what was produced. Sage develops it in the open under the Apache License 2.0. As of August 2026 it holds 4.05 petabytes of data, serves 9,434 registered active users a month, and delivers 5.9 million downloads a month. I write in support of the RedTwin proposal submitted by Prof. Giovanni Vigna and Prof. Christopher Kruegel (UC Santa Barbara) and Prof. Adam Doupé and Prof. Tiffany Bao (Arizona State University).

Relationship to the proposing team. For full transparency: my connection to UC Santa Barbara is historical. I was an intern in the Computer Security Lab at UCSB in 2008 and later completed my Ph.D. at UCSB in the Department of Computer Science, under the supervision of Prof. Subhash Suri, and I have known Prof. Vigna and Prof. Kruegel since then. I am not a member of the proposing team, hold no appointment at UCSB or ASU, am not a subawardee, have no current or pending joint funding with any of the PIs, would receive no funds under this award, and have no financial interest in the project. Neither I nor Sage Bionetworks has a research collaboration with the proposing team at present. My interest is institutional: the sector Sage serves is one this work is designed to protect. The assessment below is my own.

Assessment of the proposed approach. The proposal opens with a regional health-care provider whose electronic health-record system runs on open-source software, and observes that this is precisely the environment in which no one is permitted to fuzz an application server or run an exploit against the identity provider. The asymmetry the proposal identifies, between attackers who probe continuously and defenders who assess rarely, is sharpest where downtime is measured in patient harm.

The hardest part, and where we may be useful. The proposal has a key insight: data is as relevant as code, and a twin whose directory is empty or whose data stores are synthetic in the wrong ways will not exhibit the attack paths that matter. That is, in my judgment, the most interesting problem in the proposal, and it sits squarely in Sage's area. Authorization decisions in a clinical stack are driven by data: directory structure and group membership, role and

2901 3rd Ave, Ste. 330, Seattle, WA 98121

Phone 206.928.8250 | **Fax** 206.928.8251 | **Web** sagebionetworks.org

Sage Bionetworks

department hierarchies, care-team relationships, device enrollment registries. A twin seeded with a hundred uniformly random users will not reproduce the privilege structure that a real attack chain traverses, and a twin seeded with real patient data is not something anyone should build. The middle ground is a research problem in its own right, and one Sage has spent years on from the data-sharing side: data with realistic structure, distributions, and relational shape, derived from real resources under proper governance and sanitized so that no individual's information is exposed in the twin.

How Sage Bionetworks contributes to open resources. Sage both holds data resources of its own and acts as a steward and broker for resources contributed by other institutions and consortia, and it maintains the governance machinery (data-use agreements, consent frameworks, access review, de-identification practice) that determines what can be shared, with whom, and under what conditions. Sage is also itself a user of the open-source ecosystem RedTwin targets: our platform runs on the same class of components named in the proposal, including relational databases, identity providers, message brokers, reverse proxies, and container orchestrators, so we would be a natural user of the resulting tooling as well as a potential source of inputs to it.

What I would hope for if the proposal is funded. My primary interest is the data-fidelity problem above, and there is a concrete form the interaction could take. Where a specific use case is well defined and has been validated against the applicable consent terms, data-use agreements, and access-review process, I would expect Sage to be able to work with the team on access to material suitable for deriving realistic, non-identifying populations for hospital digital twins, meaning structure, distributions, and relationships rather than records. Where direct access is not appropriate, I would expect us to help specify what a defensible synthetic substitute would have to preserve. Any such arrangement would be subject to Sage's governance review and to the conditions set by the original data contributors; that process exists independently of this award and is the mechanism through which the question would be answered.

I believe this work addresses a real and worsening exposure in a sector that has very little margin, and I am pleased to support the proposal.

Sincerely,

Luca Foschini, Ph.D.
President and Chief Executive Officer Sage Bionetworks

Luca Foschini

2901 3rd Ave, Ste. 330, Seattle, WA 98121

Phone 206.928.8250 | **Fax** 206.928.8251 | **Web** sagebionetworks.org